COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.5 · Secure Protocols

Mestre CyberSec · **Aula 4.5 — Secure Protocols** (4:47) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: SEGURO: SSH 22, HTTPS 443, SFTP 22, SNMPv3, LDAPS 636, TLS 1.2/1.3, IPsec, WPA3. INSEGURO: Telnet 23, FTP 21, HTTP 80, SNMPv1/v2, LDAP 389, WEP/WPA, SMTP 25 sem TLS.

💡 Highlights que a prova CompTIA cobra

- Portas seguras: SSH 22, HTTPS 443, SFTP, SNMPv3, LDAPS 636
- INSEGURAS (proibidas na prova): Telnet 23, FTP 21, HTTP 80, SNMPv1/v2

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'replaces telnet'=SSH (remote secure)

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.5 — Secure Protocols)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Shell Seguro (SSH)

Secure Shell (SSH) é um protocolo criptográfico usado para acesso remoto seguro por linha de comando, tunelamento e transferência de arquivos em rede não confiável. Normalmente usa a porta TCP 22 e substitui o Telnet inseguro.

⚠ ***Armadilha CompTIA:*** *Se a prova disser 'substitui Telnet' ou 'remote seguro', marque SSH (porta 22). Não confunda com Telnet (23), que envia tudo em texto claro.*

• Protocolo de Transferência de Hipertexto Seguro (HTTPS)

HTTPS é o HTTP encapsulado em TLS, fornecendo comunicação web criptografada e com integridade. Usa a porta TCP 443 e autentica servidores por certificados.

⚠ ***Armadilha CompTIA:*** *HTTPS = HTTP + TLS, porta 443. Se aparecer HTTP 80, é inseguro; a substituição segura é HTTPS 443.*

• Protocolo de Transferência de Arquivos Seguro (SFTP)

Secure File Transfer Protocol (SFTP) transfere arquivos com segurança por uma sessão SSH, oferecendo criptografia e autenticação. Costuma usar a porta TCP 22, não as portas FTP 20/21.

⚠ ***Armadilha CompTIA:*** *SFTP não é FTP sobre TLS; ele roda sobre SSH na porta 22. FTP na porta 21 é inseguro e deve ser substituído.*

• Protocolo Simples de Gerência de Rede v3 (SNMPv3)

SNMPv3 é a versão segura do SNMP que adiciona autenticação e privacidade (criptografia) para gerência de rede. Substitui SNMPv1 e SNMPv2c inseguros.

⚠ ***Armadilha CompTIA:*** *SNMPv3 = autenticação e criptografia (authPriv); SNMPv1/v2c usam community strings em texto claro. Portas comuns: UDP 161/162.*

• Protocolo Leve de Acesso a Diretório Seguro (LDAPS)

LDAPS é LDAP sobre TLS/SSL, fornecendo consultas e autenticação em serviços de diretório criptografadas. Normalmente usa a porta TCP 636, enquanto LDAP usa a porta 389 em texto claro.

⚠ ***Armadilha CompTIA:*** *LDAP 389 é inseguro; LDAPS 636 é seguro. Se a questão pedir diretório criptografado, escolha LDAPS.*

• Segurança da Camada de Transporte (TLS)

Transport Layer Security (TLS) é um protocolo criptográfico que fornece confidencialidade e integridade para dados em trânsito. As versões seguras atuais são TLS 1.2 e TLS 1.3; SSL é obsoleto.

⚠️ ***Armadilha CompTIA:*** *A prova considera TLS 1.2/1.3 seguro e SSL/antigas versões inseguras. HTTPS, LDAPS e SMTPS dependem de TLS.*

• Segurança do Protocolo de Internet (IPsec)

IPsec é um conjunto de protocolos que protege comunicações IP autenticando e criptografando pacotes. É usado em VPNs e suporta modos transporte e túnel.

⚠️ ***Armadilha CompTIA:*** *IPsec para VPN: ESP fornece criptografia; AH fornece autenticação/integridade. IKE usa UDP 500/4500 para negociação.*

• Acesso Protegido Wi-Fi 3 (WPA3)

WPA3 é o padrão mais recente de segurança Wi-Fi, usando Simultaneous Authentication of Equals (SAE) para melhorar autenticação por senha e criptografia. Substitui WEP e WPA inseguros.

⚠️ ***Armadilha CompTIA:*** *WPA3 = SAE e forward secrecy; WEP/WPA são inseguros. Se perguntar melhor segurança wireless, escolha WPA3.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um administrador de rede de uma empresa de manufatura atualmente gerencia switches principais por meio de uma sessão de linha de comando que transmite todas as teclas e credenciais em texto claro. A empresa deseja manter o gerenciamento remoto por CLI, mas proteger credenciais administrativas e comandos de configuração contra captura de pacotes. Qual protocolo deve ser implementado?

A) SNMPv3

B) HTTPS

C) SSH

D) SFTP

QUESTÃO 2 · CENÁRIO DE EXAME

O portal do cliente de uma empresa de varejo está acessível em http://shop.example.com. Durante uma revisão, auditores descobriram que credenciais de login e cookies de sessão podem ser interceptados em Wi-Fi público. O portal deve continuar usando navegador, mas proteger os dados em trânsito. Qual protocolo deve ser habilitado?

A) SFTP

B) HTTPS

C) IPsec

D) LDAPS

QUESTÃO 3 · CENÁRIO DE EXAME

Uma equipe financeira troca relatórios grandes entre um servidor Linux interno e o servidor de um parceiro. Os servidores já possuem chaves SSH configuradas para administração, e a equipe precisa de um método de transferência de arquivos criptografado que use essas chaves. Qual protocolo deve ser usado?

A) SFTP

B) FTP

C) TFTP

D) SNMPv3

QUESTÃO 4 · CENÁRIO DE EXAME

Um centro de operações de rede monitora disponibilidade de roteadores e utilização de interfaces. O sistema atual usa community strings e capturas mostram que essas strings e detalhes do dispositivo atravessam a rede em texto claro. A gerência quer autenticação e criptografia para o polling. Qual versão deve ser configurada?

A) SNMPv1

B) SNMPv2c

C) LDAPS

D) SNMPv3

QUESTÃO 5 · CENÁRIO DE EXAME

Um aplicativo de RH realiza consultas de usuários no Active Directory enviando credenciais de simple bind a um servidor de diretório. Uma avaliação de segurança descobriu que as credenciais são legíveis na rede interna. O aplicativo pode ser atualizado para usar um protocolo de diretório seguro. Qual deve ser implementado?

A) LDAP na 389

B) LDAPS na 636

C) SNMPv3

D) SFTP

QUESTÃO 6 · CENÁRIO DE EXAME

Um servidor web hospeda um aplicativo interno. Uma varredura mostra que ele ainda aceita SSL 3.0, TLS 1.0 e TLS 1.1, além de TLS 1.2 e TLS 1.3. A equipe de segurança quer remover protocolos criptográficos fracos mantendo o aplicativo disponível via HTTPS. O que deve ser feito?

A) Habilitar WPA3 no servidor

B) Exigir SNMPv3 para todas as sessões web

C) Desabilitar SSL 3.0/TLS 1.0/1.1 e permitir apenas TLS 1.2/1.3

D) Substituir HTTPS por SFTP

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa precisa conectar duas redes de escritório pela internet. O tráfego entre os sites inclui replicação de banco de dados proprietária que deve ser criptografada e autenticada na camada de rede, de forma transparente para as aplicações. Qual tecnologia deve ser usada?

A) VPN IPsec

B) Proxy reverso HTTPS

C) SFTP

D) LDAPS

QUESTÃO 8 · CENÁRIO DE EXAME

Uma rede sem fio corporativa usa uma única chave pré-compartilhada para todos os funcionários. Uma auditoria recente recomenda um padrão de segurança wireless que ofereça proteção mais forte contra ataques de dicionário offline e sigilo forward. Qual deve ser implantado?

A) WEP

B) WPA2-PSK

C) WPA3-Personal com SAE

D) Autenticação aberta com portal cativo

QUESTÃO 9 · CENÁRIO DE EXAME

Um aplicativo de inventário interno legado suporta apenas HTTP e não pode ser modificado. Administradores remotos precisam acessar sua interface web com segurança de fora do escritório, sem expor a porta HTTP diretamente e sem implantar uma VPN site-to-site. Qual abordagem deve ser usada?

A) Configurar um túnel SSH para encaminhar uma porta local ao aplicativo

B) Habilitar SNMPv3 no servidor do aplicativo

C) Usar LDAPS para a interface web

D) Exigir WPA3 nos notebooks dos administradores

QUESTÃO 10 · CENÁRIO DE EXAME

O servidor de e-mail de uma organização envia e-mails de notificação contendo links de redefinição de senha. Uma captura de pacotes mostra que a sessão SMTP não está criptografada, e as mensagens podem ser lidas em trânsito. O servidor de e-mail deve continuar enviando mensagens, mas proteger o conteúdo entre servidores. Qual configuração deve ser implementada?

A) Continuar usando SMTP na porta 25 sem TLS

B) Habilitar TLS no relay SMTP com STARTTLS ou SMTPS

C) Configurar IMAPS na porta 993 para transporte de mensagens

D) Habilitar SNMPv3 para monitoramento do servidor de e-mail

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — SSH

O SSH fornece acesso remoto a terminal criptografado e substitui o Telnet em texto claro. SNMPv3 é para dados de monitoramento/gerenciamento, não para CLI interativa. HTTPS protege gerenciamento web. SFTP é para transferência de arquivos.

Questão 2: Alternativa B — HTTPS

HTTPS usa TLS para criptografar tráfego HTTP, incluindo credenciais e cookies. SFTP é transferência de arquivos, IPsec protege tráfego IP em nível de rede, e LDAPS é para consultas de diretório.

Questão 3: Alternativa A — SFTP

SFTP opera sobre SSH na porta 22 e usa credenciais/chaves SSH existentes. FTP e TFTP enviam dados em texto claro; SNMPv3 é para monitoramento.

Questão 4: Alternativa D — SNMPv3

SNMPv3 suporta autenticação e privacidade, ou seja, criptografia. SNMPv1 e SNMPv2c usam community strings em texto claro. LDAPS é um protocolo de diretório, não de monitoramento.

Questão 5: Alternativa B — LDAPS na 636

LDAPS criptografa LDAP sobre TLS na porta 636. LDAP na 389 é texto claro, a menos que use StartTLS. SNMPv3 e SFTP não são protocolos de autenticação de diretório.

Questão 6: Alternativa C — Desabilitar SSL 3.0/TLS 1.0/1.1 e permitir apenas TLS 1.2/1.3

TLS 1.2 e TLS 1.3 são versões modernas seguras; versões legadas de SSL e TLS são vulneráveis. WPA3 é para wireless, SNMPv3 é para monitoramento e SFTP é para transferência de arquivos.

Questão 7: Alternativa A — VPN IPsec

IPsec protege tráfego IP entre gateways e é adequado para VPN site-to-site. HTTPS protege aplicações web, SFTP transfere arquivos e LDAPS protege consultas de diretório.

Questão 8: Alternativa C — WPA3-Personal com SAE

WPA3-Personal usa SAE, que mitiga ataques de dicionário offline e oferece sigilo forward. WEP e WPA2-PSK são mais fracos, e autenticação aberta não fornece criptografia.

Questão 9: Alternativa A — Configurar um túnel SSH para encaminhar uma porta local ao aplicativo

O encaminhamento de porta SSH cria um túnel criptografado para tráfego HTTP. SNMPv3 é para monitoramento, LDAPS é para serviços de diretório e WPA3 protege apenas o enlace wireless.

Questão 10: Alternativa B — Habilitar TLS no relay SMTP com STARTTLS ou SMTPS

SMTP com TLS criptografa o transporte de e-mail. SMTP na porta 25 sem TLS é texto claro. IMAPS é para recuperação de mensagens, e SNMPv3 é para monitoramento.